External Security Configuration Assessment

LOCAL QA — Golden path / ƏFĶĦΘ¥YhI <script> & "TOO"

Security Snapshot

Generated: 2026-10-24 19:03 UTC · Report: 1179e2b9-3c4d-4849-af28-648f03edfedb

Policy: starter-risk-1 · assessment-2

Limited external configuration assessment

This is a limited external configuration assessment, not a penetration test, compliance audit or guarantee of safety. Missing, failed or stale checks do not prove security. Human task completion is not technical resolution.

Executive summary

Saved evidence is available for 1 of 1 enrolled domains. Assessment status: Ready. Findings below describe only the observed scope.

Coverage and recorded findings	Count
Currently authorized domains	1
Unverified or expired domains	0
Domains with usable saved evidence	1
Domains without usable evidence	0
Domains with stale evidence	0
Historical findings excluded from assessed scope	0

Open / High: 1 · Open / Low: 3 · Open / Medium: 2

Top priorities

No.	Risk level / domain	Recorded issue
1	High qa-defense.example.com	Certificate renewal was due within 7 days TLS_CERTIFICATE_ACTION
2	Medium qa-defense.example.com	Multiple SPF policies were observed DNS_SPF_MULTIPLE
3	Medium qa-defense.example.com	Review a basic DMARC policy format problem DNS_DMARC_POLICY

Scope and method

Only authorized domain names and saved, supported observations are assessed: DNS email-record context, TLS certificate trust/renewal, and root HTTP/HTTPS responses and selected headers. Observation times differ from the report creation time. Failed, inconclusive and unrecorded checks remain gaps, not successful checks.

Excluded: internal networks, malware detection, account auditing, exploitation, port sweeping, continuous monitoring and compliance certification. Current domain proof does not establish permission for every service behind a domain.

Domain	Scope status	Last collection (UTC)
qa-defense.example.com	Evidence available Completed	2026-10-24 19:03 UTC

Findings and evidence

01 / Certificate renewal was due within 7 days

High · Open · qa-defense.example.com

Why this matters

Certificate problems can stop customers or staff reaching this exact website over trusted HTTPS.

Recommended next step

Ask the hosting contact to check renewal, the certificate names and full trusted chain. Install the correct certificate, then run an authorized scan again.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

An explicit trust error or a measured renewal deadline supports a transport maintenance priority.

Ordering labels: urgency 2/3; observed relevance 2/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Conclusive

TLS_CERTIFICATE_ACTION · starter-risk-1 · /app/findings/484ff062-476a-4f70-aa45-975892b1a532

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
TLS_CERTIFICATE 2026-10-24 19:03 UTC pass	not_before: 1792865032 not_after: 1793300632 protocol: TLSv1.3	6734c0a9-f385-4d19-ba94-a7b04350d00c

Limits of this conclusion

One exact hostname and pinned endpoint was checked. This does not enumerate every certificate, cipher or supported protocol.

02 / Multiple SPF policies were observed

Medium · Open · qa-defense.example.com

Why this matters

Multiple SPF policies at the same name can cause mail-authentication evaluation errors if this domain sends mail.

Recommended next step

Ask the mail administrator to consolidate intended senders into one SPF policy at this exact name. Do not overwrite the DNS ownership challenge. Rerun the authorized DNS check.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

The persisted exact v=spf1 record count identifies multiplicity; medium priority reflects configuration correctness, not compromise.

Ordering labels: urgency 1/3; observed relevance 1/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Conclusive

DNS_SPF_MULTIPLE · starter-risk-1 · /app/findings/781cdbd0-6c2e-43ff-9360-ef6480f148c2

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
DNS_SPF_PRESENT 2026-10-24 19:03 UTC Needs attention	record_count: 2	f47c6ac9-5253-4c87-b23b-470a1ae267f7

Limits of this conclusion

Outbound email use and SPF mechanisms/includes are unknown. One record or no record is not proof that outbound email is correctly authorized.

03 / Review a basic DMARC policy format problem

Medium · Open · qa-defense.example.com

Why this matters

The saved basic DMARC observation warrants a mail-policy review; it does not establish email compromise.

Recommended next step

Ask the mail administrator to confirm whether this exact domain sends mail, review DMARC syntax and alignment, and stage enforcement after monitoring legitimate senders. Rerun the authorized DNS check.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

Missing or monitor-only policy with inbound-mail context is low priority. A single basic malformed policy is medium priority for configuration review.

Ordering labels: urgency 1/3; observed relevance 1/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Contextual

DNS_DMARC_POLICY · starter-risk-1 · /app/findings/e4220bbf-32b0-435c-8e82-327b2ce49b04

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
DNS_DMARC_PRESENT 2026-10-24 19:03 UTC Needs attention	policy: malformed record_count: 1	22a6688d-f852-438c-8fd6-6854d2239139

Limits of this conclusion

MX suggests inbound handling only. Outbound email, alignment, reporting and full DMARC syntax were not assessed; p=none can be intentional.

04 / Review the response content-type safeguard

Low · Open · qa-defense.example.com

Why this matters

The inspected response did not demonstrate nosniff, a browser content-type hardening control.

Recommended next step

Ask the application contact to review MIME types and set X-Content-Type-Options: nosniff where appropriate, then rerun an authorized scan.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

Missing or unexpected nosniff is low-priority contextual hardening, never proof of XSS.

Ordering labels: urgency 0/3; observed relevance 1/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Contextual

HTTPS_NOSNIFF · starter-risk-1 · /app/findings/0363113f-7bc6-44c9-9bb1-e515284259df

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
TLS_CERTIFICATE 2026-10-24 19:03 UTC pass	not_before: 1792865032 not_after: 1793300632 protocol: TLSv1.3	6734c0a9-f385-4d19-ba94-a7b04350d00c
HTTPS_RESPONSE 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	1cd2bdce-9df0-4998-97d1-0b6cb36c76b5
HTTPS_NOSNIFF 2026-10-24 19:03 UTC Needs attention	header: x-content-type-options observation: missing	d372239e-9beb-4b69-a814-fbc4b7c244cc

Limits of this conclusion

Response content type and body were not collected. Browser applicability needs review; API or non-browser services may have different requirements.

05 / HTTP root does not immediately redirect to HTTPS

Low · Open · qa-defense.example.com

Why this matters

The observed HTTP root can be reached without the HTTPS redirect expected for this site's public entry point.

Recommended next step

Ask the hosting contact to redirect the HTTP root to HTTPS on the same exact hostname. Recheck both root responses with an authorized scan.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

A successful HTTP root response alongside inspected HTTPS supports a low-priority entry-point hardening recommendation.

Ordering labels: urgency 0/3; observed relevance 1/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Contextual

HTTP_ROOT_REDIRECT · starter-risk-1 · /app/findings/37797127-03af-42b0-b53d-aea0c1bf4546

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
TLS_CERTIFICATE 2026-10-24 19:03 UTC pass	not_before: 1792865032 not_after: 1793300632 protocol: TLSv1.3	6734c0a9-f385-4d19-ba94-a7b04350d00c
HTTPS_RESPONSE 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	1cd2bdce-9df0-4998-97d1-0b6cb36c76b5
HTTP_REDIRECT 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	97218b54-bf58-488d-855c-e955b51351f3

Limits of this conclusion

Only HEAD/GET at / was observed. No credentials, other paths or later redirect hops were tested; this is not proof of interception.

06 / Review the HTTPS transport policy

Low · Open · qa-defense.example.com

Why this matters

The inspected HTTPS root did not demonstrate the limited HSTS condition used by this policy.

Recommended next step

Have the hosting contact review Strict-Transport-Security and deploy a suitable positive max-age after checking HTTPS coverage. Do not enable includeSubDomains or preload without checking their scope. Rerun the authorized check.

How to verify the change

Rerun this rule in a new authorized check. A completed task alone does not confirm resolution.

Why this priority

A missing or unrecognized HSTS value on an inspected HTTPS response is contextual, low-priority hardening.

Ordering labels: urgency 0/3; observed relevance 1/2. These are not risk scores.

Last observation: 2026-10-24 19:03 UTC · Confidence: Contextual

HTTPS_HSTS · starter-risk-1 · /app/findings/71e854bf-3ac9-4bda-8dd1-92daf05dada3

Technical evidence

Check / observation time	Recorded technical values	Observation ID:
TLS_CERTIFICATE 2026-10-24 19:03 UTC pass	not_before: 1792865032 not_after: 1793300632 protocol: TLSv1.3	6734c0a9-f385-4d19-ba94-a7b04350d00c
HTTPS_RESPONSE 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	1cd2bdce-9df0-4998-97d1-0b6cb36c76b5
HTTPS_HSTS 2026-10-24 19:03 UTC Needs attention	header: strict-transport-security observation: missing	94867f26-bf34-478f-b882-60c19556faec

Limits of this conclusion

Only the root response and a simple max-age condition were checked. No exploitation or whole-origin coverage is established.

Remediation work

Human task status does not determine finding resolution.

Task status	Count
Done	1

Certificate renewal was due within 7 days

qa-defense.example.com · Task status: Done · Finding status: Open

Owner label: LOCAL QA — Әкімші

Ask the hosting contact to check renewal, the certificate names and full trusted chain. Install the correct certificate, then run an authorized scan again.

Updated: 2026-10-24 19:03 UTC · /app/tasks/eb7712a0-0305-4a0e-970d-a7a92ae908d0

Task marked done - remediation not yet verified

Reading this assessment

A finding is a supported configuration condition, not necessarily an exploitable vulnerability. Severity and priority come from the recorded policy; no CVSS score or CVE is invented. Inconclusive means evidence was insufficient. Stale means the observation may no longer describe the current configuration. Only a later comparable check confirms resolution.

This is a limited external configuration assessment, not a penetration test, compliance audit or guarantee of safety. Missing, failed or stale checks do not prove security. Human task completion is not technical resolution.

Appendix: saved check inventory

Protocol identifiers, evidence values and source references below are preserved exactly. Empty values are not a claim of safety. References identify records inside the authenticated workspace; they grant no public access.

qa-defense.example.com

Evidence available

Ownership proof valid until: 2026-11-23 19:03 UTC

38b7de16-d233-43eb-b415-741f85df1054 · /app/assets#asset-3fecb953-4078-4e97-aa02-93864d91f3d8

Needs attention: 8 · Informational: 4 · Not checked: 0 · pass: 1

Check / observation time	Recorded technical values	Observation ID:
DNS_ADDRESS 2026-10-24 19:03 UTC Informational	No additional retained values.	fb06226b-a353-4dae-b1b1-317ed6330989
DNS_DMARC_PRESENT 2026-10-24 19:03 UTC Needs attention	policy: malformed record_count: 1	22a6688d-f852-438c-8fd6-6854d2239139
DNS_MX_PRESENT 2026-10-24 19:03 UTC Informational	record_count: 1	34c2dce8-673e-46de-88bb-8e67f1b363f7
DNS_SPF_PRESENT 2026-10-24 19:03 UTC Needs attention	record_count: 2	f47c6ac9-5253-4c87-b23b-470a1ae267f7
HTTPS_CSP 2026-10-24 19:03 UTC Needs attention	No additional retained values.	47115d6d-f662-4527-afc8-a8146969908f
HTTPS_FRAME 2026-10-24 19:03 UTC Needs attention	No additional retained values.	7e3af904-38ea-4df9-abf5-6e06b2f1deb0
HTTPS_HSTS 2026-10-24 19:03 UTC Needs attention	header: strict-transport-security observation: missing	94867f26-bf34-478f-b882-60c19556faec
HTTPS_NOSNIFF 2026-10-24 19:03 UTC Needs attention	header: x-content-type-options observation: missing	d372239e-9beb-4b69-a814-fbc4b7c244cc
HTTPS_PERMISSIONS 2026-10-24 19:03 UTC Needs attention	No additional retained values.	91ff5a53-d005-4f85-ae8c-abbe11313e91
HTTPS_REFERRER 2026-10-24 19:03 UTC Needs attention	No additional retained values.	eab306d5-13ef-4a70-b8de-2e313ebaa425
HTTPS_RESPONSE 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	1cd2bdce-9df0-4998-97d1-0b6cb36c76b5

Check / observation time	Recorded technical values	Observation ID:
HTTP_REDIRECT 2026-10-24 19:03 UTC Informational	status: 200 method: HEAD path: /	97218b54-bf58-488d-855c-e955b51351f3
TLS_CERTIFICATE 2026-10-24 19:03 UTC pass	not_before: 1792865032 not_after: 1793300632 protocol: TLSv1.3	6734c0a9-f385-4d19-ba94-a7b04350d00c